

# Cyber Threat Intelligence

## Executive Briefing

Report Date: July 06, 2026

Generated: 2026-07-06 01:26 UTC | Classification: TLP:AMBER

Prepared by: Auto-CTI Autonomous Threat Intelligence Pipeline

### 1. Risk Statistics Summary

| Critical | High | Medium | Low | Total |
|----------|------|--------|-----|-------|
| 4        | 11   | 4      | 1   | 20    |

### 2. Executive Summary

As of July 06, 2026, the security operations center has completed a comprehensive assessment of 20 identified vulnerabilities, categorized as 4 Critical, 11 High, 4 Medium, and 1 Low severity findings. Our current organizational risk posture is classified as High, indicating significant exposure to potential exploitation of internal services and authentication mechanisms. The primary threat is identified as CVE-2026-49360, SQL Injection and File System Access within the Recce server, which presents an immediate risk of unauthenticated remote data exfiltration and persistent system compromise. Given the severity of these exposures, the recommended response posture is immediate remediation and temporary isolation of affected network segments. Executive leadership is advised to authorize an emergency patching cycle to mitigate these critical gaps within the defined 24-hour window.

### 3. Critical Action List

1. Immediate isolation of the Recce server and application of the vendor-supplied security patch for CVE-2026-49360 within 24 hours.
2. Mandatory rotation of all 9router JWT secrets and implementation of secure environment variables to remediate the authentication bypass associated with CVE-2026-49352 within 24 hours.
3. Deployment of emergency ingress filtering and updated file-handling logic for the LaunchServer FileServerHandler to mitigate CVE-2026-54617 within 24 hours.
4. Immediate suspension of fast-mcp-telegram module operations and implementation of token validation hardening for CVE-2026-52830 within 24 hours.
5. Reconfiguration of Steeltoe management port access controls and implementation of strict Host header validation to address CVE-2026-50194 within 48 hours.
6. Execute remediation protocols for the remaining 10 high-severity vulnerabilities identified in the audit within 72 hours.

4. Quick Reference: All Identified Vulnerabilities

| CVE ID         | Finding Name                         | CVSS | Severity | Urgency | CWE      |
|----------------|--------------------------------------|------|----------|---------|----------|
| CVE-2026-49360 | SQL Injection and File System Acc... | 9.8  | Critical | 88/100  | CWE-73   |
| CVE-2026-49352 | Authentication Bypass via Hardcod... | 9.8  | Critical | 88/100  | CWE-798  |
| CVE-2026-54617 | Unauthenticated Path Traversal in... | 9.8  | Critical | 88/100  | CWE-22   |
| CVE-2026-52830 | Token Path Traversal in Telegram ... | 9.4  | Critical | 85/100  | CWE-22   |
| CVE-2026-50194 | Management Port Isolation Bypass     | 8.2  | High     | 74/100  | CWE-288  |
| CVE-2026-2092  | Unauthorized SAML Access via Vali... | 7.7  | High     | 69/100  | CWE-1287 |
| CVE-2026-49353 | Local Access Bypass via Header Sp... | 7.5  | High     | 68/100  | CWE-290  |
| CVE-2026-46599 | Denial of Service via Image Decom... | 7.5  | High     | 68/100  | CWE-770  |
| CVE-2026-52792 | Source Disclosure via NTFS Filena... | 7.5  | High     | 68/100  | CWE-69   |
| CVE-2026-50200 | Sensitive Data Leakage in Actuator   | 7.5  | High     | 68/100  | CWE-200  |
| CVE-2026-50196 | Registry Poisoning in Eureka Disc... | 7.5  | High     | 68/100  | CWE-20   |
| CVE-2026-49289 | Denial of Service via XPath Trans... | 7.5  | High     | 68/100  | CWE-400  |
| CVE-2026-52829 | Mempool Corruption in Zebra Addre... | 8.2  | High     | 68/100  | CWE-617  |
| CVE-2026-52834 | Integer Overflow in jxl-grid         | 7.3  | High     | 66/100  | CWE-122  |
| CVE-2026-49284 | Improper SAML Response Validation    | 8.1  | High     | 64/100  | CWE-345  |
| CVE-2026-50201 | Sensitive Actuators Exposed to Re... | 6.5  | Medium   | 59/100  | CWE-269  |
| CVE-2026-50202 | Improper JWKS Cache Isolation        | 5.9  | Medium   | 53/100  | CWE-668  |
| CVE-2026-49292 | Improper Access Control on Databa... | 6.5  | Medium   | 48/100  | CWE-862  |
| CVE-2026-50267 | Insecure TLS Key File Permissions    | 4.7  | Medium   | 42/100  | CWE-312  |
| CVE-2026-50268 | Insecure Padding Choice in Steelt... | 1.9  | Low      | 12/100  | CWE-256  |

5. Detailed Vulnerability Findings

CVE-2026-49360

Finding: SQL Injection and File System Access

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-73

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190, T1068

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | High |

Description:

The Recce server component contains an unauthenticated SQL execution vulnerability within the DuckDB integration layer. This flaw stems from a failure to properly sanitize user-supplied input before passing it to the database engine. Attackers can leverage this to perform arbitrary local file read and write operations, compromising the confidentiality and integrity of the host system.

Proof of Concept (PoC):

An unauthenticated remote attacker identifies the Recce server endpoint. The attacker sends a crafted malicious SQL query string targeting the underlying DuckDB integration via the server's input interface. The server fails to validate the query, allowing the DuckDB engine to execute commands with the privileges of the service account. This grants the attacker full read and write access to the server's local file system.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49360>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49360>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49360>

CVE-2026-49352

Finding: Authentication Bypass via Hardcoded JWT Secret

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-798

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1190, T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | High |

Description:

9router utilizes a hardcoded, default fallback secret for signing and validating JSON Web Tokens (JWT). The vulnerability exists because the application defaults to this static secret when a dynamic configuration is missing, rendering all authentication checks effectively null for an attacker who knows the secret. This allows full, unauthenticated administrative access to the 9router platform.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the 9router authentication service. The attacker generates a custom JWT with elevated administrative claims, signing it using the widely-known default hardcoded secret. The application verifies the signature successfully and grants the attacker full administrative privileges. This leads to complete compromise of the 9router system data and configuration.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49352>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49352>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49352>

CVE-2026-54617

Finding: Unauthenticated Path Traversal in FileServerHandler

CVSS v3.1 Score: 9.8 | Severity: Critical | Urgency Score: 88/100 | CWE: CWE-22

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1210

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | High |

Description:

The LaunchServer FileServerHandler contains an unauthenticated path traversal vulnerability. The failure stems from insufficient input sanitization of file paths passed to the handler, allowing directory climbing characters to bypass intended access boundaries. This enables an attacker to read arbitrary files from the server's local file system.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a specially crafted GET request to the FileServerHandler component with a path containing sequence like '.././etc/passwd'. The handler fails to resolve or filter the path correctly and reads the target file instead of the intended public content. This results in the disclosure of sensitive system information to the attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-54617>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-54617>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-54617>

CVE-2026-52830

Finding: Token Path Traversal in Telegram Integration

CVSS v3.1 Score: 9.4 | Severity: Critical | Urgency Score: 85/100 | CWE: CWE-22

Score Provenance: CNA Official  
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:L

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | High      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | Low  |

Description:

The fast-mcp-telegram module suffers from a path traversal vulnerability via manipulated bearer tokens that bypasses Telegram session protection. The issue exists because the module does not adequately validate the path component of the token, allowing an attacker to navigate the file system relative to the session storage. This enables an attacker to retrieve session tokens of other users or system configurations.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the Telegram gateway endpoint with a Bearer token containing traversal sequences such as '../././sessions/admin.json'. The fast-mcp-telegram module concatenates this token with the base session path without sufficient validation. This causes the application to open and leak the contents of the target system file to the attacker.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52830>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52830>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52830>

CVE-2026-50194

Finding: Management Port Isolation Bypass

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 74/100 | CWE: CWE-288

Score Provenance: CNA Official

MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | None |

Description:

Steeltoe is vulnerable to a management-port isolation bypass via spoofed Host headers. The vulnerability exists because the application relies on the Host header to differentiate between the standard service port and the management port, a check that is easily bypassed by external requests. An attacker can use this to access restricted administrative actuators exposed on the management port.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a request to the primary service port of a Steeltoe application. The attacker injects a malicious 'Host' header designed to trick the Steeltoe request router into treating the request as directed to the management port. The system erroneously authorizes the request and serves administrative data, allowing the attacker to bypass port-level isolation controls.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50194>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50194>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50194>

CVE-2026-2092

Finding: Unauthorized SAML Access via Validation Failure

CVSS v3.1 Score: 7.7 | Severity: High | Urgency Score: 69/100 | CWE: CWE-1287

Score Provenance: CNA Official

MITRE ATT&CK: T1550

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:H/PR:L/UI:N/S:C/C:H/I:L/A:L

|                     |         |
|---------------------|---------|
| Attack Vector       | Network |
| Privileges Required | Low     |
| Scope               | Changed |
| Integrity Impact    | Low     |

|                        |      |
|------------------------|------|
| Attack Complexity      | High |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | Low  |

Description:

Keycloak fails to properly validate encrypted SAML assertions, leading to unauthorized access. The root cause is a deficiency in the logic that handles the decryption and signature verification sequence for SAML tokens. This vulnerability allows an attacker to bypass authentication requirements under specific configuration conditions.

Proof of Concept (PoC):

An authenticated user with low privileges intercepts an encrypted SAML assertion sent to the Keycloak identity provider. The attacker manipulates the assertion's contents to grant themselves elevated permissions while preserving a structure that triggers the vulnerable decryption path. Keycloak fails to verify the integrity of the decrypted assertion before granting access, allowing the attacker to assume unauthorized roles.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-2092>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-2092>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-2092>

CVE-2026-49353

Finding: Local Access Bypass via Header Spoofing

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-290

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

|                     |           |                        |      |
|---------------------|-----------|------------------------|------|
| Attack Vector       | Network   | Attack Complexity      | Low  |
| Privileges Required | None      | User Interaction       | None |
| Scope               | Unchanged | Confidentiality Impact | High |
| Integrity Impact    | None      | Availability Impact    | None |

Description:

9router implements an incomplete fix for local-only access controls, permitting bypasses via HTTP Host header manipulation. The root cause is an improper trust relationship in which the application validates request origin based on easily forged request headers rather than network-layer authentication. This allows remote attackers to access restricted administrative functions intended for local use only.

Proof of Concept (PoC):

An unauthenticated remote attacker targets the 9router web management console. The attacker modifies the HTTP request to include a spoofed 'Host' header set to 'localhost'. The application logic incorrectly validates this header to authorize the request as coming from a trusted local context. This allows the attacker to interact with restricted endpoints otherwise blocked from the public internet.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49353>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49353>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49353>

CVE-2026-46599

Finding: Denial of Service via Image Decompression

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-770

Score Provenance: Estimated (No Official CVSS) - Vector Recalculated  
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

|               |         |                   |     |
|---------------|---------|-------------------|-----|
| Attack Vector | Network | Attack Complexity | Low |
|---------------|---------|-------------------|-----|

|                     |           |
|---------------------|-----------|
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | High |

**Description:**

The golang.org/x/image/tiff package is vulnerable to resource exhaustion during the processing of PackBits compressed image data. The flaw occurs because the decompressor fails to validate the allocated buffer size against the decompressed data requirements before allocating memory. This enables an attacker to trigger excessive CPU or memory consumption, leading to a service crash or system-wide denial of service.

**Proof of Concept (PoC):**

An unauthenticated remote attacker uploads a maliciously crafted TIFF image to an application utilizing the golang.org/x/image/tiff library. The library's PackBits decompression function attempts to process the file, triggering a massive, unchecked memory allocation request. This causes the target application to terminate due to resource depletion, effectively denying service to all legitimate users.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-46599>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-46599>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-46599>

## CVE-2026-52792

**Finding: Source Disclosure via NTFS Filenames**

**CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-69**

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1592

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | None |

**Description:**

The Algernon server is vulnerable to server-side script source disclosure when deployed on Windows platforms due to improper handling of NTFS-specific filename syntax. This flaw occurs because the server does not canonicalize the request path, allowing attackers to bypass file extensions by using specific alternate NTFS data stream formats. This results in the disclosure of potentially sensitive application source code.

**Proof of Concept (PoC):**

An unauthenticated remote attacker accesses a known script file hosted on an Algernon server running on Windows. The attacker appends a special NTFS alternate data stream suffix to the URI, such as 'script.lua:hidden'. The server incorrectly treats this as a request for the raw file content instead of executing the script, causing the source code to be returned to the requester.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52792>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52792>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52792>



CVE-2026-50200

Finding: Sensitive Data Leakage in Actuator

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-200

Score Provenance: CNA Official

MITRE ATT&CK: T1005

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | None |

Description:

Steeltoe's environment sanitizer incorrectly handles connection strings, causing embedded database passwords to be leaked in actuator endpoints. The root cause is a failure in the regex-based sanitization logic to identify and mask sensitive parameters within multi-part configuration strings. This results in the exposure of cleartext credentials to unauthorized observers.

Proof of Concept (PoC):

An unauthenticated remote attacker accesses the '/actuator/env' endpoint on a Steeltoe application. The endpoint response includes the complete application environment settings, where the sanitization routine has failed to detect and mask a database connection string containing an embedded 'password=' parameter. The attacker extracts this password to gain unauthorized access to the backend database.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50200>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50200>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50200>

CVE-2026-50196

Finding: Registry Poisoning in Eureka Discovery

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-20

Score Provenance: CNA Official

MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | High |

Description:

Steeltoe.Discovery.Eureka incorrectly handles unrecognized `DataCenterInfo.Name` fields, which can lead to the poisoning of the entire registry fetch process. The flaw occurs because the library does not discard or sanitize unexpected data formats before updating the local registry cache. This allows a remote attacker to induce a denial-of-service condition by invalidating the service discovery registry.



Proof of Concept (PoC):

An unauthenticated remote attacker submits a registration request to the Eureka server with a crafted 'DataCenterInfo.Name' field containing unexpected characters. The Steeltoe client library processing the fetch response fails to handle this unrecognized input correctly and corrupts its internal registry map. Subsequent attempts by the application to access discovery services fail, resulting in a system-wide denial of service.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50196>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50196>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50196>

CVE-2026-49289

Finding: Denial of Service via XPath Transform

CVSS v3.1 Score: 7.5 | Severity: High | Urgency Score: 68/100 | CWE: CWE-400

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1499

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H

|                     |           |                        |      |
|---------------------|-----------|------------------------|------|
| Attack Vector       | Network   | Attack Complexity      | Low  |
| Privileges Required | None      | User Interaction       | None |
| Scope               | Unchanged | Confidentiality Impact | None |
| Integrity Impact    | None      | Availability Impact    | High |

Description:

SimpleSAMLphp is vulnerable to a potential Denial of Service (DoS) attack through the processing of XPath transforms in XML security signatures. The flaw occurs because the implementation fails to restrict the depth or complexity of the XPath queries, enabling an attacker to trigger resource-exhausting computational cycles. This allows an unauthenticated attacker to crash the authentication service.

Proof of Concept (PoC):

An unauthenticated remote attacker sends a SAML assertion containing a malicious XML signature with a deeply nested or highly recursive XPath transform. The SimpleSAMLphp engine attempts to resolve this transform, consuming excessive CPU and memory on the host server. This forces the application to become unresponsive, effectively denying service for all authentication requests.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49289>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49289>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49289>

CVE-2026-52829

Finding: Mempool Corruption in Zebra Address Book

CVSS v3.1 Score: 8.2 | Severity: High | Urgency Score: 68/100 | CWE: CWE-617

Score Provenance: Estimated (Unverified) - Vector Recalculated  
MITRE ATT&CK: T1190

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:H

|               |         |                   |     |
|---------------|---------|-------------------|-----|
| Attack Vector | Network | Attack Complexity | Low |
|---------------|---------|-------------------|-----|

|                     |           |
|---------------------|-----------|
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |      |
|------------------------|------|
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | High |

**Description:**

The Zebra Address Book implementation suffers from a memory corruption issue triggered by improper IPv4-mapped address handling in the mempool. The error originates from a lack of validation during the address conversion function, causing the system to write data beyond the allocated memory pool boundaries. An attacker can exploit this to potentially achieve service instability or remote execution.

**Proof of Concept (PoC):**

An unauthenticated remote attacker sends a specially crafted network request containing a malformed IPv4-mapped address to the Zebra Address Book service. The service attempts to process the address through its mempool management routine, triggering an assertion failure or out-of-bounds write. This results in an immediate service crash, demonstrating a severe denial-of-service vector.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52829>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52829>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52829>

## CVE-2026-52834

**Finding: Integer Overflow in jxl-grid**

**CVSS v3.1 Score: 7.3 | Severity: High | Urgency Score: 66/100 | CWE: CWE-122**

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:L

|                     |           |
|---------------------|-----------|
| Attack Vector       | Network   |
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |      |
|------------------------|------|
| Attack Complexity      | Low  |
| User Interaction       | None |
| Confidentiality Impact | Low  |
| Availability Impact    | Low  |

**Description:**

The jxl-grid library on 32-bit platforms is vulnerable to out-of-bounds writes caused by an integer overflow during coordinate arithmetic. The failure occurs when calculating buffer indices for image data, where large values cause the integer to wrap around, bypassing range checks. An attacker can exploit this to perform arbitrary memory corruption, potentially leading to remote code execution.

**Proof of Concept (PoC):**

An unauthenticated remote attacker submits a maliciously crafted image file to a system using the 32-bit jxl-grid library. The image contains dimension metadata designed to trigger an integer overflow during the internal coordinate indexing calculation. This results in the library writing data out-of-bounds, corrupting heap memory and allowing the attacker to alter application state or flow.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-52834>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-52834>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-52834>

## CVE-2026-49284

### Finding: Improper SAML Response Validation

**CVSS v3.1 Score: 8.1 | Severity: High | Urgency Score: 64/100 | CWE: CWE-345**

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1550

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:N

|                     |                  |
|---------------------|------------------|
| Attack Vector       | <b>Network</b>   |
| Privileges Required | <b>None</b>      |
| Scope               | <b>Unchanged</b> |
| Integrity Impact    | <b>High</b>      |

|                        |                 |
|------------------------|-----------------|
| Attack Complexity      | <b>Low</b>      |
| User Interaction       | <b>Required</b> |
| Confidentiality Impact | <b>High</b>     |
| Availability Impact    | <b>None</b>     |

#### Description:

SimpleSAMLphp Service Provider (SP) improperly validates SAML responses when an unsigned `InResponseTo` attribute is combined with a signed assertion lacking the corresponding `SubjectConfirmationData/InResponseTo`. The root cause is a failure to enforce mutual binding between the response and the assertion, allowing attackers to inject unsolicited assertions. An attacker can use this to spoof an identity and gain unauthorized access to the application.

#### Proof of Concept (PoC):

An attacker intercepts or crafts a SAML response message and presents it to a SimpleSAMLphp SP. The attacker uses an unsigned 'InResponseTo' header in conjunction with a valid, signed assertion that omits the 'InResponseTo' field in 'SubjectConfirmationData'. The application incorrectly accepts this mismatch as legitimate, allowing the attacker to impersonate a valid user account.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49284>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49284>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49284>

## CVE-2026-50201

### Finding: Sensitive Actuators Exposed to Restricted Users

**CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 59/100 | CWE: CWE-269**

Score Provenance: CNA Official

MITRE ATT&CK: T1068, T1005

#### CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

|                     |                  |
|---------------------|------------------|
| Attack Vector       | <b>Network</b>   |
| Privileges Required | <b>Low</b>       |
| Scope               | <b>Unchanged</b> |
| Integrity Impact    | <b>None</b>      |

|                        |             |
|------------------------|-------------|
| Attack Complexity      | <b>Low</b>  |
| User Interaction       | <b>None</b> |
| Confidentiality Impact | <b>High</b> |
| Availability Impact    | <b>None</b> |

#### Description:

Steeltoe's administrative actuators, such as heapdump and env, require only 'Restricted' permissions, allowing unauthorized access to highly sensitive system data. The vulnerability is caused by improper mapping of security roles to sensitive endpoints during the application bootstrap. This allows authenticated users with low privileges to exfiltrate system memory snapshots and environment variables.

**Proof of Concept (PoC):**

An authenticated user with low privileges sends a GET request to the '/actuator/heapdump' endpoint in a Steeltoe-based application. The server logic incorrectly validates the 'Restricted' role as sufficient, granting the user access to the heap dump file. The attacker parses the dump for credentials and internal configuration data, leading to deeper system compromise.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50201>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50201>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50201>

**CVE-2026-50202****Finding: Improper JWKS Cache Isolation**

**CVSS v3.1 Score: 5.9 | Severity: Medium | Urgency Score: 53/100 | CWE: CWE-668**

Score Provenance: CNA Official

MITRE ATT&CK: T1190

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:H/PR:H/UI:N/S:U/C:H/I:H/A:N

|                     |                  |
|---------------------|------------------|
| Attack Vector       | <b>Network</b>   |
| Privileges Required | <b>High</b>      |
| Scope               | <b>Unchanged</b> |
| Integrity Impact    | <b>High</b>      |

|                        |             |
|------------------------|-------------|
| Attack Complexity      | <b>High</b> |
| User Interaction       | <b>None</b> |
| Confidentiality Impact | <b>High</b> |
| Availability Impact    | <b>None</b> |

**Description:**

The Steeltoe library uses a static JWKS cache that is shared globally across different security schemes and is never invalidated. The design flaw stems from the failure to key the cache by the specific authorization scheme or to implement a TTL mechanism for the cached entries. This allows cross-scheme credential manipulation and potential reuse of compromised keys.

**Proof of Concept (PoC):**

An attacker with administrative privileges updates the JWKS configuration for a less sensitive application scheme. Due to the lack of isolation, this change propagates into the global static cache and affects other, more sensitive authentication schemes using the same Steeltoe instance. The attacker then utilizes a token generated for the lesser-privileged context to authenticate against the target protected resource.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50202>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50202>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50202>

**CVE-2026-49292****Finding: Improper Access Control on Database Init**

**CVSS v3.1 Score: 6.5 | Severity: Medium | Urgency Score: 48/100 | CWE: CWE-862**

Score Provenance: Estimated (Unverified) - Vector Recalculated

MITRE ATT&CK: T1190

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:L

|               |                |
|---------------|----------------|
| Attack Vector | <b>Network</b> |
|---------------|----------------|

|                   |            |
|-------------------|------------|
| Attack Complexity | <b>Low</b> |
|-------------------|------------|

|                     |           |
|---------------------|-----------|
| Privileges Required | None      |
| Scope               | Unchanged |
| Integrity Impact    | Low       |

|                        |      |
|------------------------|------|
| User Interaction       | None |
| Confidentiality Impact | None |
| Availability Impact    | Low  |

**Description:**

The Kiwi TCMS `/init-db/` page incorrectly remains accessible and functional after the initial database setup is completed. The vulnerability is caused by a missing check for the application's current installation state before rendering the initialization interface. This exposes critical setup functions to unauthorized access, potentially allowing an attacker to modify or overwrite database configurations.

**Proof of Concept (PoC):**

An unauthenticated remote attacker navigates to the public `/init-db/` endpoint on a production Kiwi TCMS instance. The application fails to check if the installation has already been locked or finalized and serves the initialization form. The attacker can then trigger database configuration changes or disrupt existing settings through the exposed interface.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-49292>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-49292>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-49292>

**CVE-2026-50267****Finding: Insecure TLS Key File Permissions**

**CVSS v3.1 Score: 4.7 | Severity: Medium | Urgency Score: 42/100 | CWE: CWE-312**

Score Provenance: CNA Official

MITRE ATT&CK: T1552

**CVSS v3.1 Scoring Criteria:**

Vector: CVSS:3.1/AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:N/A:N

|                     |           |
|---------------------|-----------|
| Attack Vector       | Local     |
| Privileges Required | Low       |
| Scope               | Unchanged |
| Integrity Impact    | None      |

|                        |      |
|------------------------|------|
| Attack Complexity      | High |
| User Interaction       | None |
| Confidentiality Impact | High |
| Availability Impact    | None |

**Description:**

Steeltoe improperly writes TLS private keys to the `/tmp` directory with world-readable permissions and fails to delete them after use. The root cause is a lack of restrictive file system flag settings during the temporary file creation process. This leads to persistent, unauthorized local disclosure of sensitive cryptographic assets.

**Proof of Concept (PoC):**

A local attacker with low-level access waits for the Steeltoe application to initiate a TLS-enabled service. The attacker monitors the system's `/tmp` directory and observes the creation of a private key file. Because the library fails to restrict permissions or delete the file, the attacker reads the key and uses it to intercept or decrypt encrypted traffic.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50267>

Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50267>

Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50267>

**CVE-2026-50268****Finding: Insecure Padding Choice in Steeltoe**

**CVSS v3.1 Score: 1.9 | Severity: Low | Urgency Score: 12/100 | CWE: CWE-256**

Score Provenance: CNA Official

MITRE ATT&CK: T1552

CVSS v3.1 Scoring Criteria:

Vector: CVSS:3.1/AV:L/AC:H/PR:H/UI:N/S:U/C:L/I:N/A:N

|                     |           |                        |      |
|---------------------|-----------|------------------------|------|
| Attack Vector       | Local     | Attack Complexity      | High |
| Privileges Required | High      | User Interaction       | None |
| Scope               | Unchanged | Confidentiality Impact | Low  |
| Integrity Impact    | None      | Availability Impact    | None |

Description:

The Steeltoe library incorrectly selects PKCS#1 v1.5 padding when OAEP is supposedly configured, weakening cryptographic protections. The failure is due to a flaw in the configuration mapping logic that defaults to the insecure padding scheme when the security context is not explicitly enforced. This potentially exposes data to padding oracle-style attacks, though exploitation requires significant prerequisite knowledge.

Proof of Concept (PoC):

A local attacker with high privileges inspects the application's runtime configuration for the Steeltoe cryptographic module. The attacker observes that despite the desired security policy, the library has fallen back to using PKCS#1 v1.5 for encryption due to the implementation flaw. By intercepting encrypted messages, the attacker attempts padding oracle analysis to recover plaintexts, which is feasible given the insecure fallback behavior.

Ref (Official): <https://nvd.nist.gov/vuln/detail/CVE-2026-50268>  
Ref (Official): <https://www.cve.org/CVERecord?id=CVE-2026-50268>  
Ref (Third-Party Verified (Tenable)): <https://www.tenable.com/cve/CVE-2026-50268>

6. Methodology & Data Sources

This report was generated by the Auto-CTI Autonomous Cyber Threat Intelligence Pipeline, an automated multi-agent system designed to simulate a real-world Security Operations Center (SOC) workflow. The pipeline operates in three sequential stages: (1) the Scout Agent collects the latest CVE disclosures from NVD, the GitHub Advisory Database, and OSV.dev, cross-referencing active threat pulses via AlienVault OTX; (2) the Triage Agent performs structured analysis using the CVSS v3.1 scoring standard, assigns CWE root-cause classifications, maps each vulnerability to relevant MITRE ATT&CK techniques, and computes a composite Urgency Score; (3) the Publisher Agent synthesizes the triaged data into this executive briefing. Every CVSS score is tagged with a Score Provenance label indicating whether it was confirmed against an official database (NVD or CNA record) or estimated by the analysis model when no official score existed. All CVE identifiers, CVSS scores, and CWE mappings are independently verifiable via the references provided in Section 5. References marked 'Fallback Search' indicate the specific CVE record was not found live at NVD or CVE.org at generation time; a source-database search link is provided instead. Severity classification follows the CVSS v3.1 standard: Critical (9.0-10.0), High (7.0-8.9), Medium (4.0-6.9), Low (0.1-3.9).

Primary Data Sources:

- NIST National Vulnerability Database (NVD) -- <https://nvd.nist.gov/>
- GitHub Advisory Database -- <https://github.com/advisories>
- OSV.dev Open Source Vulnerabilities -- <https://osv.dev/>
- CVE Services API (MITRE CNA Records) -- <https://cveawg.mitre.org/>
- OpenCVE -- <https://www.opencve.io/>

- AlienVault Open Threat Exchange (OTX) -- <https://otx.alienvault.com/>
- MITRE ATT&CK Framework -- <https://attack.mitre.org/>
- CVSS v3.1 Specification -- <https://www.first.org/cvss/v3.1/specification-document>
- Common Weakness Enumeration (CWE) -- <https://cwe.mitre.org/>
- CVE Program -- <https://www.cve.org/>